

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**
2. As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks. **(20 Mark)**.
3. Using **Nmap Aggressive Scan (-A)** on **scanme.nmap.org**, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations. **(10 Marks)**

Code of Conduct:

I B.MALLIKA(192324234)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

B.MALLIKA

RUBRICS FOR CALCULATION

Social Engineering Simulation

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.
Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well-justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well-organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

ANSWERS:

OSINT Email Enumeration Assessment using theHarvester

Aim

To perform an Open Source Intelligence (OSINT) assessment on the target domain tesla.com using theHarvester and identify publicly available email addresses, subdomains, hosts, and IP addresses.

Theory

theHarvester is an OSINT tool used to gather publicly available information about a target organization from search engines, certificate transparency logs, and other public sources. It helps security professionals understand what information about an organization is exposed online.

Commands

Update package list: `sudo apt update`

Explanation:

Updates the local package database before installing software.

Install theHarvester: `sudo apt install theharvester`

Explanation:

Installs theHarvester on Kali Linux if it is not already installed.

Verify installation: `theHarvester --version`

Explanation:

Displays the installed version of theHarvester.

Enumerate public information: `theHarvester -d tesla.com -b all`

Explanation:

- `-d tesla.com` specifies the target domain.
 - `-b all` queries all supported public data sources.
-

```
Session Actions Edit View Help

(mallika1@SIMATS1)-[~]
$ sudo apt update
[sudo] password for mallika1:
Hit:1 http://http.kali.org/kali kali-rolling InRelease
856 packages can be upgraded. Run 'apt list --upgradable' to see them.

(mallika1@SIMATS1)-[~]
$
```

```
(mallika1@SIMATS1)-[~]
$ sudo apt install theharvester
The following package was automatically installed and is no longer required:
  iucode-tool
Use 'sudo apt autoremove' to remove it.

Upgrading:
  theharvester

Summary:
  Upgrading: 1, Installing: 0, Removing: 0, Not Upgrading: 855
  Download size: 743 kB
  Space needed: 22.5 kB / 3,218 MB available

Get:1 http://kali.download/kali kali-rolling/main amd64 theharvester all 4.11
.1-0kali1 [743 kB]
Fetched 743 kB in 1s (559 kB/s)
(Reading database... 424772 files and directories currently installed.)
Preparing to unpack .../theharvester_4.11.1-0kali1_all.deb...
Unpacking theharvester (4.11.1-0kali1) over (4.10.1-0kali2)...
Setting up theharvester (4.11.1-0kali1)...
Installing new version of config file /etc/theHarvester/api-keys.yaml...
Processing triggers for kali-menu (2026.2.6)...
```


- Attackers can impersonate IT support, HR, or administrators using publicly known names, email formats, or department information to request sensitive information.
-

Countermeasures

1. Minimize publicly exposed email addresses.
2. Implement SPF, DKIM, and DMARC.
3. Use Multi-Factor Authentication (MFA).
4. Conduct regular phishing awareness training.
5. Monitor publicly available information using OSINT tools.
6. Use generic contact addresses where appropriate instead of publishing individual employee emails.

Phishing Awareness Simulation using GoPhish

Aim

To conduct a phishing awareness simulation using GoPhish with dummy employee accounts and analyze user interactions.

Theory

GoPhish is an open-source phishing simulation platform used for employee awareness training. It allows organizations to safely test how users respond to phishing emails and identify areas for improvement.

Commands

Make the GoPhish binary executable

```
chmod +x gophish
```

Explanation:

Grants execute permission to the GoPhish application.

Start GoPhish

```
sudo ./gophish
```

Explanation:

Starts the GoPhish admin interface and phishing server.

Access the Dashboard

Open:

<https://127.0.0.1:3333>

Log in using the credentials displayed in the terminal.

Steps Performed

1. Launch GoPhish.
 2. Create a sending profile.
 3. Create an email template.
 4. Create a landing page.
 5. Import dummy employee accounts.
 6. Launch the phishing campaign.
 7. Monitor the campaign dashboard.
-

Sample Email Template

Subject: Password Verification Required

Body:

Dear Employee,

The IT department has initiated a mandatory password verification process.

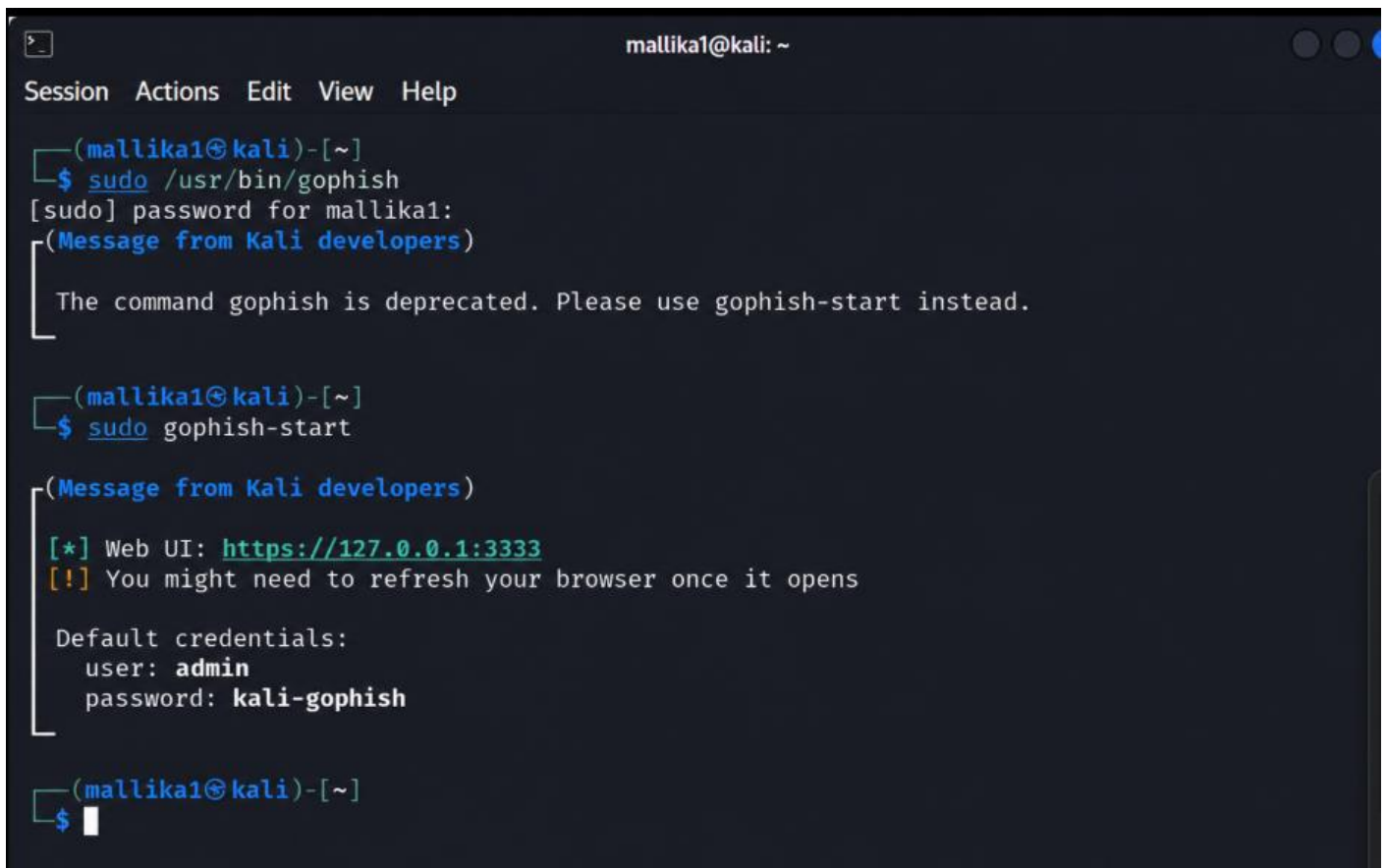
Please verify your account using the secure company portal.

Thank you,

IT Support

Use only dummy accounts in your lab.

Screenshot



```
mallika1@kali: ~  
Session Actions Edit View Help  
(mallika1@kali)-[~]  
$ sudo /usr/bin/gophish  
[sudo] password for mallika1:  
(Message from Kali developers)  
The command gophish is deprecated. Please use gophish-start instead.  
(mallika1@kali)-[~]  
$ sudo gophish-start  
(Message from Kali developers)  
[*] Web UI: https://127.0.0.1:3333  
[!] You might need to refresh your browser once it opens  
Default credentials:  
user: admin  
password: kali-gophish  
(mallika1@kali)-[~]  
$
```

Recommendations

- Conduct phishing awareness training regularly.
- Encourage users to verify email senders before responding.
- Report suspicious emails promptly.
- Enable MFA.
- Deploy advanced email filtering.
- Verify urgent requests through a second communication channel.

3.Nmap Aggressive Scan on scanme.nmap.org

Aim

To perform an aggressive Nmap scan on **scanme.nmap.org** and identify open ports, services, versions, and operating system details.

Theory

Nmap is a network scanning tool used to discover hosts, identify open ports, detect running services, estimate the operating system, and gather version information.

Commands

Verify installation

Bash

```
nmap --version
```

Explanation:

Displays the installed Nmap version.

Perform Aggressive Scan

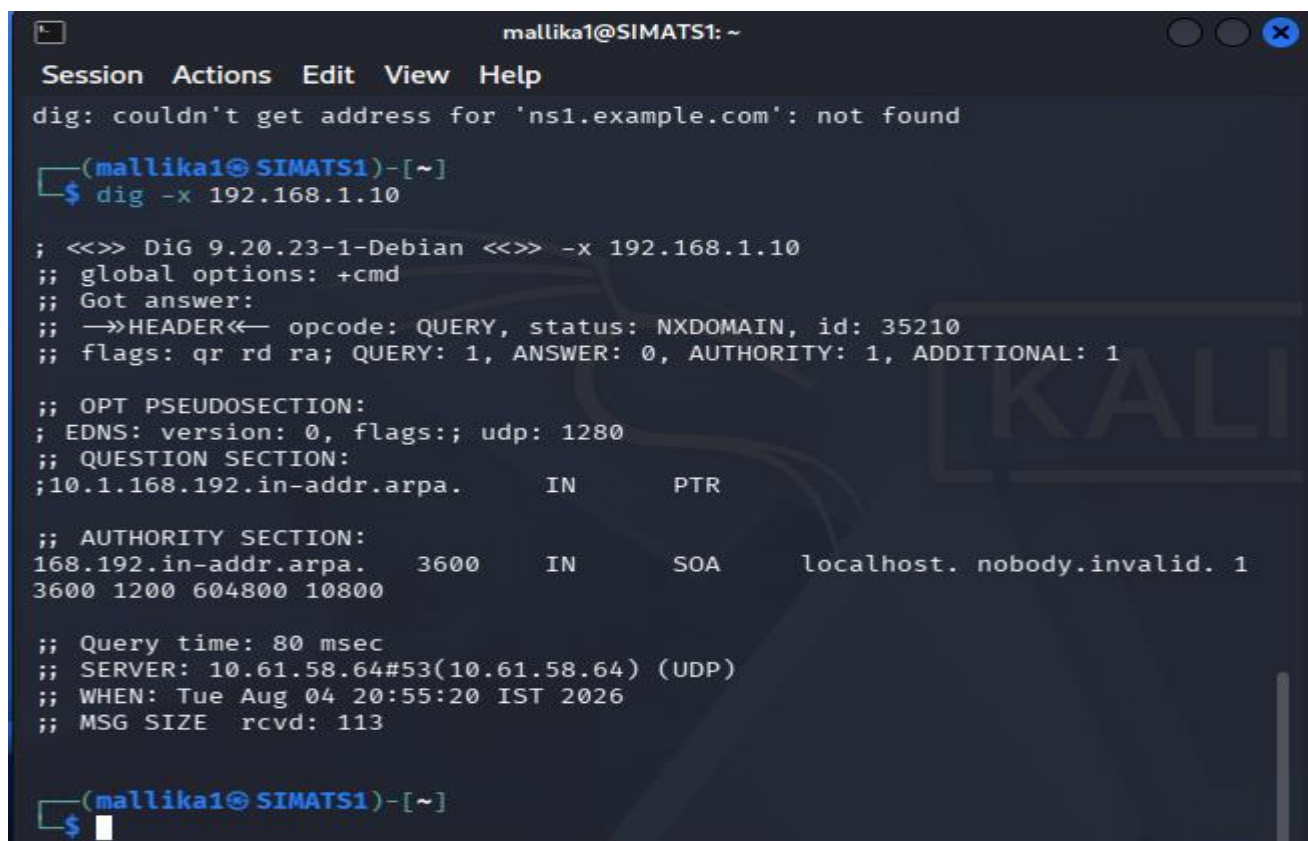
Bash

```
nmap -A scanme.nmap.org
```

Explanation:

- -A enables OS detection, version detection, script scanning, and traceroute.
-

Screenshot



```
mallika1@SIMATS1: ~  
Session Actions Edit View Help  
dig: couldn't get address for 'ns1.example.com': not found  
  
(mallika1@SIMATS1)-[~]  
$ dig -x 192.168.1.10  
  
; <<>> DiG 9.20.23-1-Debian <<>> -x 192.168.1.10  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 35210  
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:; udp: 1280  
;; QUESTION SECTION:  
;10.1.168.192.in-addr.arpa.      IN      PTR  
  
;; AUTHORITY SECTION:  
168.192.in-addr.arpa.  3600    IN      SOA     localhost. nobody.invalid. 1  
3600 1200 604800 10800  
  
;; Query time: 80 msec  
;; SERVER: 10.61.58.64#53(10.61.58.64) (UDP)  
;; WHEN: Tue Aug 04 20:55:20 IST 2026  
;; MSG SIZE rcvd: 113  
  
(mallika1@SIMATS1)-[~]  
$
```

Findings

Record the actual results from your scan.

Open Ports

Port	Service	Version
(Actual results)		

Operating System

Record the OS information reported by Nmap.

Service Versions

Record the versions reported by Nmap.

Social Engineering Attack Methodology (Hypothetical)

If an attacker learns what services and software versions are in use, they may:

- Craft convincing emails that reference the organization's actual technology.
- Impersonate IT support requesting a software update.
- Send fake security notices related to identified services.
- Increase the credibility of phishing emails by mentioning real infrastructure.

This describes a hypothetical attack path for awareness and defense planning.

Defensive Recommendations

1. Keep systems updated and patched.
2. Disable unnecessary services.
3. Limit information exposed in service banners.
4. Use network segmentation.
5. Deploy intrusion detection and monitoring.
6. Train employees to verify requests from IT support.
7. Enable MFA for administrative accounts.

Conclusion

These experiments demonstrate how publicly available information, phishing simulations, and network reconnaissance can help organizations identify security risks and strengthen their defenses. By reducing information exposure, improving employee awareness, and maintaining secure configurations, organizations can significantly lower the risk of phishing and social engineering attacks.